

ARQUITETURA DE SEGURANÇA E PRIVACIDADE

Sumário

2

- Introdução
- Desenvolver plano de segurança e privacidade
- Administração da segurança e privacidade
- Mecanismos de segurança e privacidade
- Considerações arquitetónicas

Introdução

3

□ Objetivo da segurança

- Proteger a rede e serviços de forma a assegurar que realizam as funções críticas corretamente
 - Definição clássica → proteção da integridade, confidencialidade, e disponibilidade
- Proteger recursos (utilizadores, aplicações, dispositivos) contra
 - Roubo
 - Destruição
 - Modificação
 - ...

Desenvolver plano de segurança e privacidade

4

□ Componente é necessário para o projeto em causa?

– Colocar as seguintes questões

Grupos com necessidades diferentes?
→ vários níveis de segurança na rede

- Que estamos a tentar resolver, ou diferenciar, com a introdução de mecanismos de segurança?
 - Esses mecanismos de segurança são suficientes?
- ### – Para responder às questões usamos o resultado da análise de risco
- Que recursos necessitam de proteção? Contra que problemas/ameaças tentamos proteger o sistema? Probabilidade de ocorrência do problema?

Informação faz parte do plano de segurança → que deve ser atualizado frequente/ (anual?)

□ Introdução de mecanismos de segurança

– **Começar simples** e avançar na complexidade quando justificado

- Introduzir alguns mecanismos apenas nalgumas áreas da rede (e.g., acesso e distribuição [servidores])
- Usar mecanismos fáceis de implementar, operar, e de fácil manutenção

Administração da segurança e privacidade

5

□ Análise de ameaças

- Processo que visa determinar **que componentes**/ativos do sistema precisam de proteção e contra **que ameaças**
 - Auxilia na determinação da localização estratégica → segurança efetiva
- Exemplos de componentes/ativos/bens do sistema
 - Estações de trabalho, servidores, elementos de rede (switches, routers, ...), software, serviços (e.g., aplicações, IP), dados (armazenados, arquivados, em trânsito, ...)
- Exemplos de ameaças
 - Acesso não autorizado a dados/serviços/software/hardware (DSSH), DoS, roubo DSSH, alteração DSSH, malware, dano físico

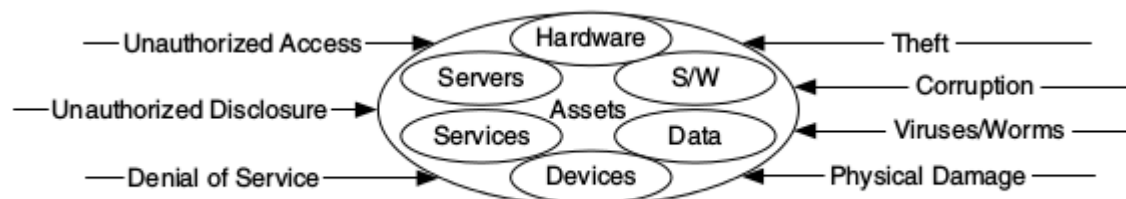


FIGURE 9.1 Potential Assets and Threats to Be Analyzed

Administração da segurança e privacidade

- **Análise de ameaças**
 - Folha com lista de ameaças e ativos
 - Para recolha e registo sobre segurança e privacidade na envolvente

A folha de registos com análise de ameaças pode depois ser distribuída pelos utilizadores, administração e staff técnico como parte do processo de análise de requisitos

Análise de ameaças é um processo subjetivo → envolver/participação de representantes dos vários grupos da organização, de forma a minimizar carácter subjetivo

Effect/ Likelihood	User Hardware	Servers	Network Devices	Software	Services	Data
Unauthorized Access	B/A	B/B	C/B	A/B	B/C	A/B
Unauthorized Disclosure	B/C	B/B	C/C	A/B	B/C	A/B
Denial of Service	B/B	B/B	B/B	B/B	B/B	D/D
Theft	A/D	B/D	B/D	A/B	C/C	A/B
Corruption	A/C	B/C	C/C	A/B	D/D	A/B
Viruses	B/B	B/B	B/B	B/B	B/C	D/D
Physical Damage	A/D	B/C	C/C	D/D	D/D	D/D

Effect:

A: Destructive B: Disabling
C: Disruptive D: No Impact

Likelihood:

A: Certain B: Likely
C: Unlikely D: Impossible

FIGURE 9.2 An Example of a Threat Analysis Worksheet for a Specific Organization

Administração da segurança e privacidade

7

□ Políticas (de segurança) e procedimentos

– Conceito

- Declarações formais sobre regras de acesso e uso do sistema, rede, e informação de forma a minimizar a exposição a ameaças de segurança
- Definem e documentam como o sistema pode ser utilizado com mínimo risco de segurança
- Clarificam utilizadores sobre: 1) o que são ameaças à segurança; 2) formas de reduzir riscos; e 3) consequências em agir contrariamente

– Duas filosofias

- Negar especificidades (regras sobre quem, o quê, onde) e permitir resto
- Permitir especificidades e negar tudo o resto → mais adequada e fácil de aplicar

– Regularmente analisar as ameaças, de forma a incluir potenciais novas ameaças e considerar novos mecanismos de segurança

– Revisão regular das políticas e procedimentos

Administração da segurança e privacidade

8

□ Políticas (de segurança) e procedimentos

- Devem incluir declarações de
 - Privacidade (monitorização, logging, e acesso)
 - Responsabilidades
 - Autenticação (políticas de passwords, acesso remoto)
 - Reporte de violações (informação de contacto, procedimentos)
- Exemplos

User Access to the System

- Authorization of use
- Authentication of identity and use of passwords
- Training and acceptance of responsibility for compliance
- Notices that corporate equipment is not private property
- Expectations of the right to privacy

Administrator Skills and Requirements for Certification

- Superusers as well as administrators

System Configuration and Management

- Maintenance
- Virus/Trojan protection
- Patching operating systems and applications
- Monitoring CERT advisories for notices of hacks
- Overseeing who can and cannot connect devices to the network
- Managing notice screens during login or startup
- Establishing what data get backed up
- Establishing what data get saved off-site
- Developing contingency computing plans
- Determining what to do when the system is attacked

Mecanismos de segurança e privacidade

9

□ Aspectos a considerar

- A escolha de um mecanismo de segurança deve considerar
 - Grau de proteção que disponibiliza
 - Impacto na capacidade dos utilizadores em realizar as suas tarefas
 - Conhecimentos necessários para instalação e configuração
 - Os custos de compra/aquisição e operação
 - Necessidade de administração e manutenção

□ Mecanismos em análise nesta apresentação

- Segurança de protocolos e aplicações
- Cifra/decifra de dados
- Perímetro de segurança da rede
- Acesso remoto seguro

Mecanismos de segurança e privacidade

10

□ Segurança física e consciencialização

- Visa proteger dispositivos contra acesso físicos, dano, ou roubo
- Formas de implementação
 - Espaços com acesso controlado (e.g., cartões de acesso)
 - Fontes de energia redundantes
 - Armazenamento e arquivo off-site
 - Sistema de alarme (e.g., fogo, acesso ilegal, ...)
 - Proteção contra desastres naturais (e.g., inundações → bombeamento de água, terremotos → racks presos ao chão e parede, ...)
 - Consciencialização → educação/formação dos utilizadores

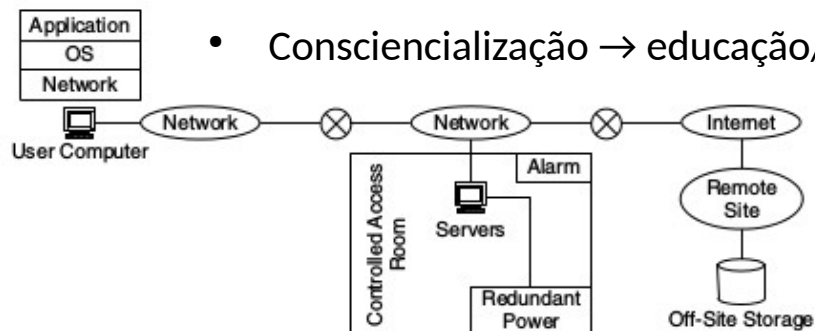


FIGURE 9.4 Areas of Physical Security

Mecanismos de segurança e privacidade

11

□ Segurança aplicacional e protocolar

– IPSec

- Fornece autenticação e cifra/decifra entre dispositivos, camada de rede
- Mecanismos: authentication header (AH), encapsulating security payload (ESP)
- Dois modos de operação: transporte e túnel

– IPSec – modo transporte

- Payload cifrado usando ESP, cabeçalho é deixado em claro

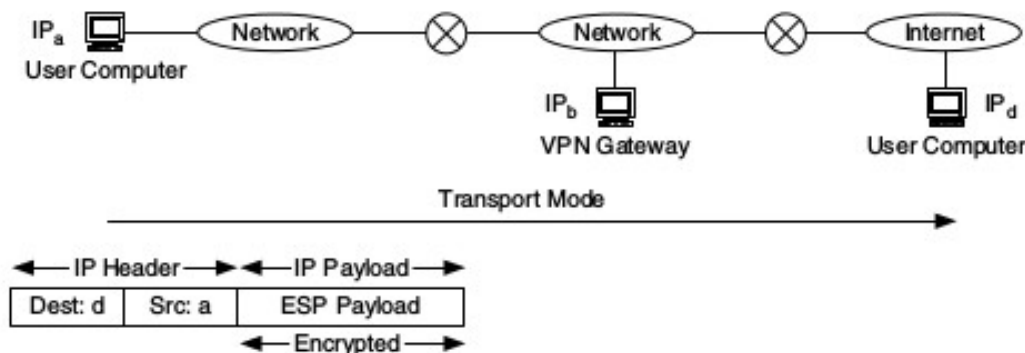


FIGURE 9.5 The Transport Mode of IPSec

Mecanismos de segurança e privacidade

12

□ Segurança aplicacional e protocolar

– IPSec – modo túnel

- Pacotes (datagramas) cifrados usando ESP
- Pacotes são encapsulados dentro de outro pacote IP
- Pacote é desencapsulado e decifrado no gateway VPN destino

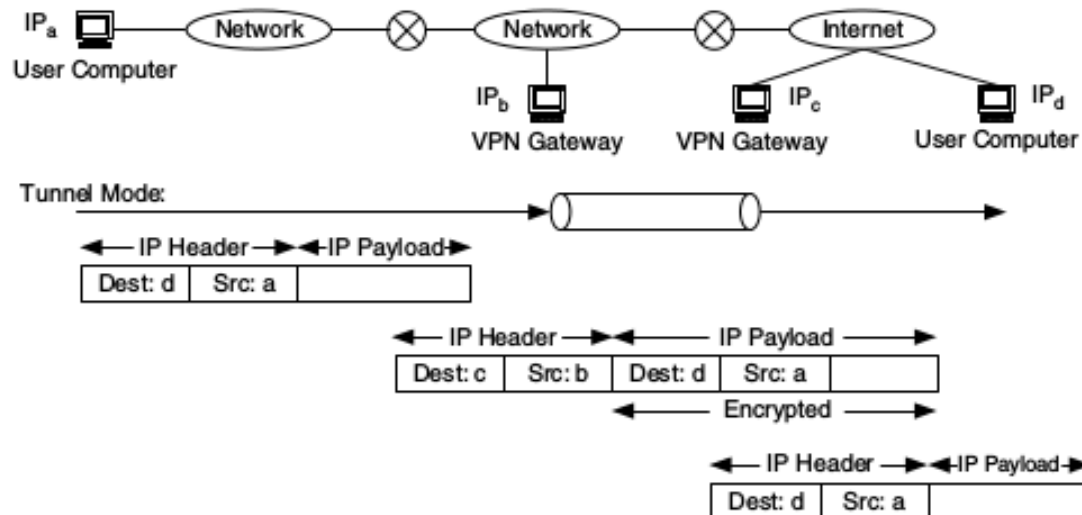


FIGURE 9.6 The Tunnel Mode of IPSec

Mecanismos de segurança e privacidade

13

□ Segurança aplicacional e protocolar

- Simple Network Management Protocol version 3 (SNMPv3)
 - Protege contra alteração, masquerading, eavesdropping ()
 - Protege contra acesso e alteração não autorizados da MIB
- Filtragem de pacotes
 - Permite a negação ou passagem de pacotes em pontos estratégicos da rede (e.g., por IP, porta, ...)

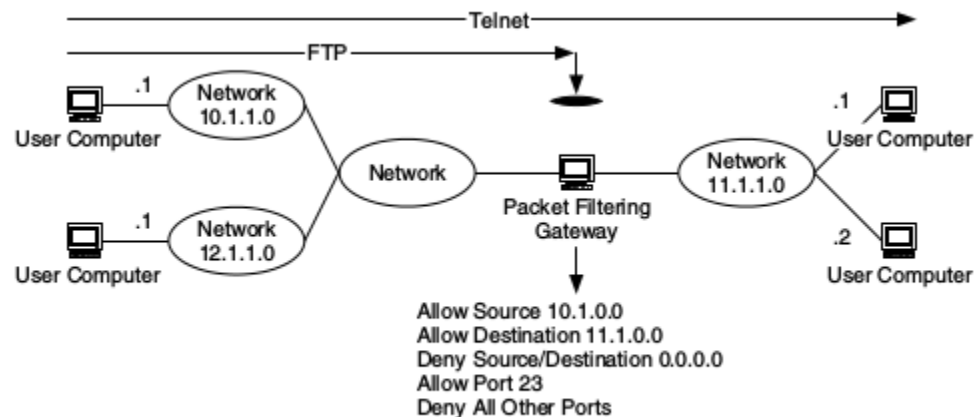


FIGURE 9.7 An Example of Packet Filtering

Mecanismos de segurança e privacidade

14

□ Cifra/decifra

- Proteção contra acessos não autorizados, destruição de recursos e dados, conhecimento de informação
 - Sistemas de chave secreta, chave dupla
 - Public key infrastructure (PKI)
 - Secure sockets library (SSL) / Transport Layer Security (TLS)
- Trade-off
 - Redução de performance (em termos de capacidade e atraso) pode variar entre 15% a 85%...

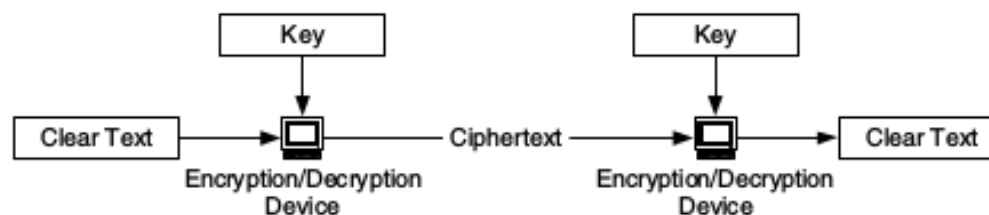


FIGURE 9.8 Encryption/Decryption of Network Traffic

Mecanismos de segurança e privacidade

15

□ Perímetro de segurança da rede

– Network address translation (NAT)

- Class A 10.x.x.x 10/8 prefix
- Class B 172.16.x.x 172.16/12 prefix
- Class C 192.168.x.x 192.168/16 prefix

- Mapeamento de endereços IP de domínios diferentes (público e privado)
- Mapeamento de endereços one-to-one → NAT estático (servidores, ...)
- Mapeamento de endereços one-to-many → NAT dinâmico (desktops, ...)
- Mapeamento de endereços e portas → network address port translation (NAPT)
- Rotas para endereços IP privados não são propagadas para a Internet → esconde estrutura da rede do exterior

– Firewall

- Filtering gateways, proxies aplicativos, ...
- Colocadas em pontos estratégicos da rede

Mecanismos de segurança e privacidade

16

□ Acesso remoto seguro

- Assenta em métodos como dial-in, sessões ponto-a-ponto, VPNs
- Segurança destes métodos assenta em mecanismos AAAA
 - Autenticação de utilizadores
 - Autorização sobre utilização de recursos
 - Contabilização sobre utilização de recursos
 - Alocação de informação de configuração (e.g., endereços, rotas, ...)

Mecanismos AAAA geralmente suportados por Network Access Server (NAS) ou Subscriber Management System (SMS)

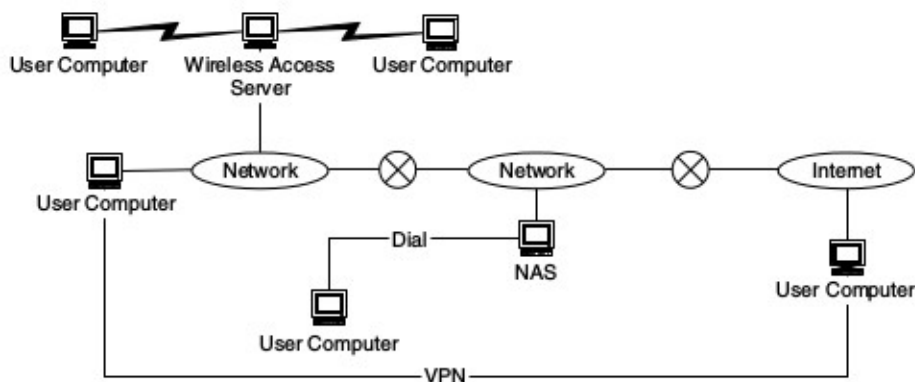


FIGURE 9.9 Remote Access Mechanisms

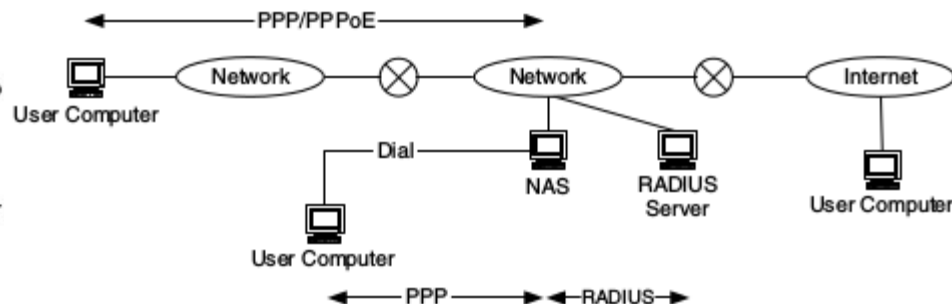


FIGURE 9.10 Remote Access Considerations

Considerações arquitetônicas

18

□ Avaliação dos mecanismos de segurança

- Começar simples e, iterativamente, adicionar complexidade
 - Modelos de arquiteturas ajudam a determinar local para mecanismos
 - Por exemplo, modelo Access/Distribution/Core, que divide a rede com base na função, pode ser usado como ponto de partida
 - Segurança pode ser aumentada em cada nível (de Access para Core), adicionando novos mecanismos (ou melhorando os já indicados)
- Exemplo

Segurança Level 2 > segurança Level 1

Fluxos de A para C (Access → Dist → Core → Dist → Access) encontram múltiplos mecanismos de segurança (intrusion detection, firewalls, cifra/decifra, e packet filters)

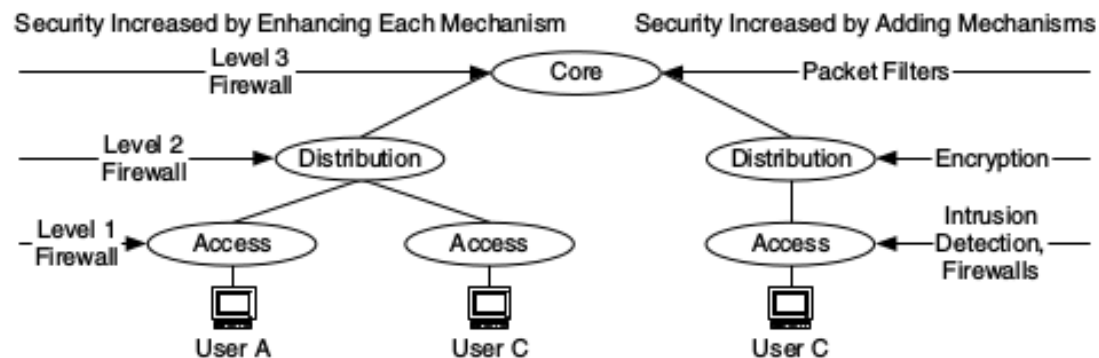


FIGURE 9.12 The Access/Distribution/Core Architectural Model as a Starting Point for Security

Considerações arquitetônicas

19

□ Avaliação dos mecanismos de segurança

- Uso de zonas/perímetros de segurança
 - São uma forma de estabelecer diferentes níveis de segurança, de acordo com os requisitos
- Duas abordagens para estabelecer zonas de segurança
 - **1) aumentar a segurança no sentido Access → Core**
 - 2) estabelecer níveis de segurança independentemente da topologia

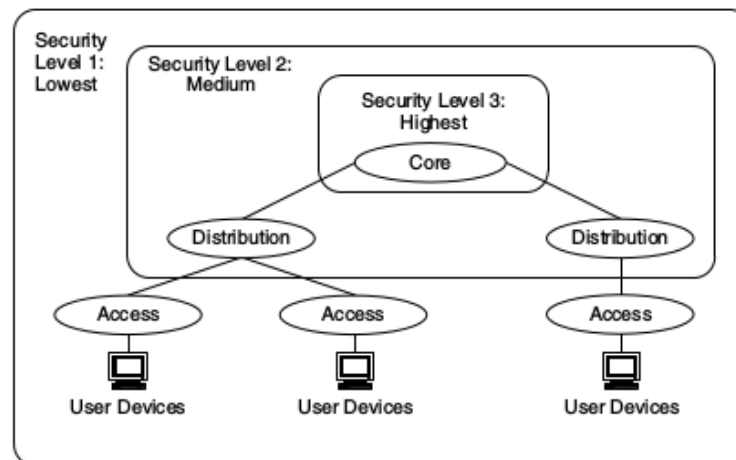


FIGURE 9.13 Security Zones Embedded within Each Other

Considerações arquitetônicas

20

- Avaliação dos mecanismos de segurança
 - Duas abordagens para estabelecer zonas de segurança
 - 1) aumentar a segurança no sentido Access → Core
 - 2) estabelecer níveis de segurança independentemente da topologia

Diferentes níveis de segurança que respondem aos requisitos de grupos de utilizadores, aplicações, dispositivos → diferentes zonas de segurança

Security Level 1 → IDS, logging
Security Level 2 → NAT, firewall
Security Level 3 e 4 → cifra/decifra, firewall, packet filtering
Security Level 5 → monitorização, logging, e autenticação

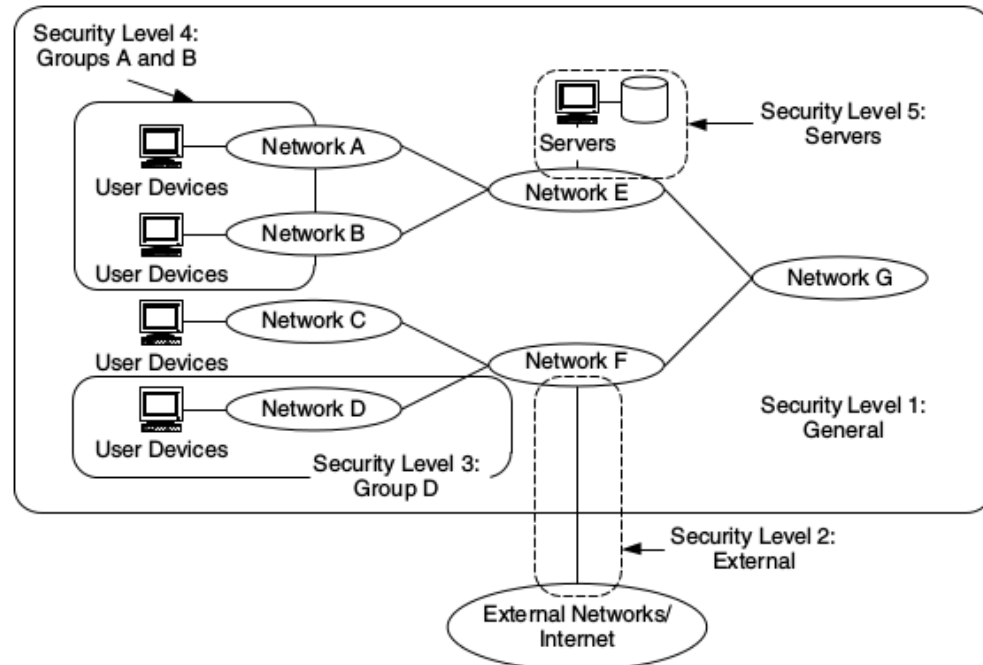


FIGURE 9.14 Developing Security Zones throughout a Network

Considerações arquitetônicas

21

□ Relações internas

- Trade-offs, dependências, e restrições
 - NAT altera o endereço IP nos cabeçalhos dos pacotes
 - Uso de cifra/decifra pode cifrar informação de campos, tornando-os ilegíveis a outros mecanismos

□ Relações externas

- Interação entre segurança e endereçamento/routing
 - Uso de NAT tem impacto no endereçamento
 - Endereçamento dinâmico tem impacto em medidas de proteção baseadas em endereços, e mecanismo de logging
- Interação entre segurança e gestão da rede
 - Segurança depende da gestão para configurar, monitorizar, gerir, e verificar níveis de segurança (mas durante ataque, in-band indisponível)

Considerações arquitetônicas

22

□ Relações externas

- Interação entre segurança e performance
 - Zonas de segurança podem restringir a performance
 - Escolher o que é mais prioritário: segurança vs. performance

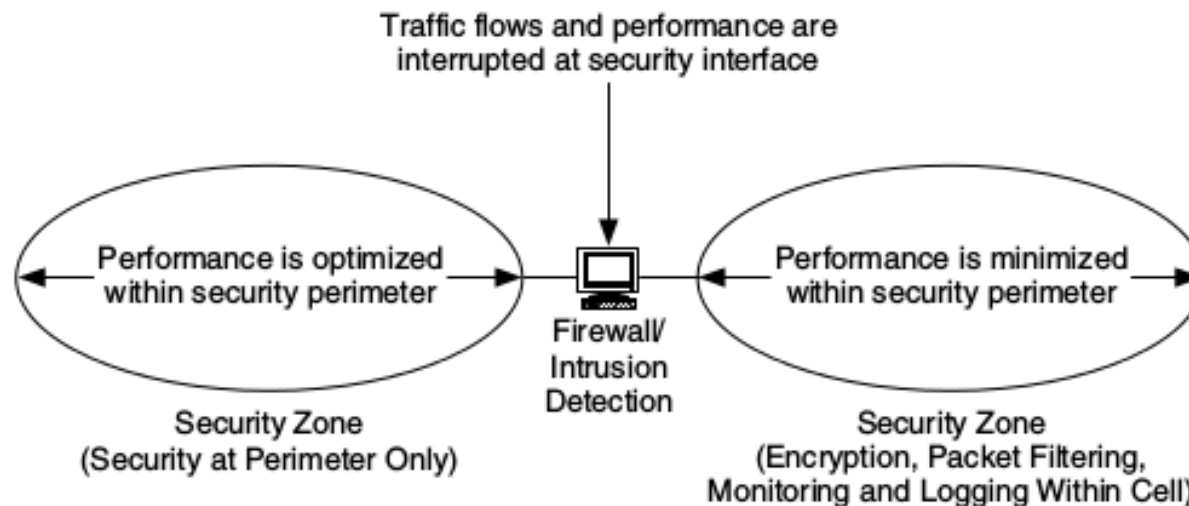


FIGURE 9.15 Security Mechanisms May Restrict or Preclude Performance within Each Zone

Bibliografia recomendada

23

- McCabe, James D. (2007). Network Analysis, Architecture & Design (3rd Ed.). San Francisco: Morgan Kaufmann Publishers. [Chapters 1-5, 10]
- Oppenheimer, P. (2010). Top-Down Network Design (3rd Ed.). Cisco Press.